BÁO CÁO CÁ NHÂN VỀ ĐẢM BẢO CHẤT LƯỢNG PHẦN MỀM

Dự án ứng dụng web quản lý dự án Vira - Phần 1, 2 và 3

Nhiệm vụ cá nhân của báo cáo là thiết lập và vận dụng hoạt động đảm bảo chất lượng phần mềm cho dự án Vira, tập trung vào rà soát mã nguồn. Trọng tâm kiểm soát gồm mức độ tuân thủ quy ước lập trình, khả năng bảo trì và phân quyền mã nguồn. Báo cáo trình bày căn cứ lựa chọn mô hình phát triển và mô hình chất lượng, tiêu chuẩn tài liệu SQA, cùng quy trình rà soát mã nguồn phù hợp với phạm vi cá nhân.

Các mô tả về kiến trúc và quy tắc kỹ thuật được đối chiếu với tài liệu dự án Vira. Các tiêu chí và quy trình dưới đây là nội dung đề xuất để thực hiện nhiệm vụ; kết quả Đạt/Không đạt cần được ghi sau khi kiểm tra mã nguồn thực tế.

1. LỰA CHỌN MÔ HÌNH PHÁT TRIỂN VÀ TIÊU CHUẨN CHẤT LƯỢNG

1.1. Phạm vi và mục tiêu lựa chọn

Vira là ứng dụng web quản lý dự án và cộng tác công việc theo cấu trúc Workspace – Project – Task/Subtask. Hệ thống hỗ trợ quản lý theo Kanban, Backlog và Sprint; phân công thành viên; bình luận; đính kèm tệp; thông báo và phân quyền. Dự án sử dụng React/Vite ở giao diện, Java/Spring Boot ở backend và MySQL để lưu trữ dữ liệu.

Trong phạm vi cá nhân, mục tiêu là xây dựng cách rà soát có căn cứ, tiêu chí và hồ sơ để kiểm tra phần mã nguồn được giao. Báo cáo ưu tiên các nội dung nêu trong đề bài: coding standards, khả năng bảo trì và phân quyền. Kết luận chỉ áp dụng cho module, file và phiên bản mã nguồn thực sự được kiểm tra.

1.2. Mô hình phát triển được lựa chọn

1.2.1. Mô hình Waterfall

Waterfall (mô hình thác nước) tổ chức hoạt động phát triển theo các giai đoạn tuần tự. Trình tự thường gặp gồm phân tích yêu cầu, thiết kế, lập trình,

kiểm thử, triển khai và bảo trì. Đầu ra của một giai đoạn là cơ sở để thực hiện và đánh giá giai đoạn tiếp theo. Theo tài liệu môn học, mô hình này phù hợp hơn với dự án có yêu cầu tương đối rõ ràng và ít thay đổi [1].

1.2.2. Căn cứ lựa chọn Waterfall cho nhiệm vụ cá nhân

Waterfall được lựa chọn làm mô hình tham chiếu vì giúp xác định thời điểm và đầu ra của hoạt động rà soát. Điểm kiểm soát chính được đặt sau khi mã nguồn của phạm vi được giao đã được lập trình và trước khi chuyển sang kiểm thử. Người thực hiện đối chiếu mã nguồn với yêu cầu, thiết kế liên quan, quy ước lập trình và quy tắc nghiệp vụ đã xác định.

Mô hình hỗ trợ lập quy trình có trình tự: xác định phạm vi; chuẩn bị tài liệu đầu vào; rà soát theo tiêu chí; ghi nhận phát hiện; xử lý và kiểm tra lại; tổng hợp kết quả. Cách trình bày này phù hợp với yêu cầu xây dựng tiêu chuẩn tài liệu, thủ tục SQA và hồ sơ kết quả.

Trong báo cáo, Waterfall là cơ sở tổ chức hoạt động SQA cá nhân, không phải kết luận rằng toàn bộ Vira đã được phát triển theo mô hình này. Các chức năng Agile của sản phẩm như Kanban và Sprint không tự xác định mô hình quy trình phát triển. Khi yêu cầu thay đổi, căn cứ rà soát và tài liệu liên quan cần được cập nhật trước khi đánh giá lại.

1.2.3. Vị trí và quan hệ của hoạt động rà soát

Hoạt động rà soát mã nguồn được đặt sau lập trình và trước kiểm thử. Rà soát giúp phát hiện sai lệch so với yêu cầu và chuẩn đã xác định bằng cách xem xét sản phẩm công việc. Hoạt động này bổ trợ nhưng không thay thế kiểm thử: rà soát xem xét mã nguồn và tài liệu; kiểm thử thực thi phần mềm để đánh giá hành vi trong tình huống cụ thể [2].

Bảng 1.1. Liên hệ Waterfall với hoạt động rà soát cá nhân

Giai đoạn	Hoạt động liên quan	Đầu ra dự kiến
Phân tích yêu cầu	Xác định yêu cầu, quy tắc quyền và hành vi cần đối chiếu.	Danh sách yêu cầu/căn cứ áp dụng.

Giai đoạn	Hoạt động liên quan	Đầu ra dự kiến
Thiết kế	Tham khảo phân chia module và luồng xử lý nếu có tài liệu.	Căn cứ thiết kế được dùng trong rà soát.
Lập trình	Xác định phiên bản mã nguồn và phạm vi file cần kiểm tra.	Mã nguồn thuộc phạm vi rà soát.
Rà soát trước kiểm thử	Đánh giá theo tiêu chí, ghi phát hiện và minh chứng.	Checklist và danh sách phát hiện.
Kiểm thử, bảo trì	Dùng phát hiện đã xử lý làm đầu vào kiểm tra tiếp hoặc tham khảo sửa đổi.	Kết quả rà soát lại và hồ sơ lưu trữ.

1.3. Tiêu chuẩn/mô hình chất lượng được lựa chọn

1.3.1. ISO/IEC 25010

Để thống nhất với Bài 05 của học phần, báo cáo tham chiếu mô hình chất lượng sản phẩm trong ISO/IEC 25010:2011. Mô hình này mô tả các đặc tính chất lượng của sản phẩm phần mềm và chất lượng trong sử dụng; mô hình sản phẩm gồm tám đặc tính: tính phù hợp chức năng, hiệu suất, tính tương thích, khả năng sử dụng, độ tin cậy, bảo mật, khả năng bảo trì và khả chuyển [3]. Do nhiệm vụ cá nhân là rà soát mã nguồn, báo cáo sử dụng mô hình chất lượng sản phẩm làm căn cứ lựa chọn tiêu chí; không đánh giá toàn bộ đặc tính và không tuyên bố sản phẩm đã được chứng nhận ISO/IEC 25010.

1.3.2. Các đặc tính áp dụng vào rà soát mã nguồn

Khả năng bảo trì (Maintainability) được ưu tiên vì nhiệm vụ yêu cầu kiểm tra coding standards và tính bảo trì. Nội dung rà soát gồm cách tổ chức module, mức độ rõ ràng của tên gọi, phân chia trách nhiệm giữa lớp/hàm, khả năng theo dõi luồng xử lý và mức độ thuận lợi khi sửa đổi. Tài liệu môn học

mô tả đặc tính này qua các khía cạnh như tính module, khả năng phân tích, sửa đổi và kiểm thử [3].

Bảo mật (Security) được lựa chọn do Vira có phân quyền ở Workspace và Project. Rà soát tập trung kiểm tra backend có xác thực quyền tại thao tác nhạy cảm hay không, quyền được áp dụng đúng vai trò và phạm vi dữ liệu hay không. Việc chỉ ẩn nút trên giao diện không đủ làm căn cứ kết luận API đã được bảo vệ; cần truy vết tới điểm xử lý phía máy chủ và đối chiếu với quy định quyền của dự án.

Tính phù hợp chức năng (Functional suitability) được dùng để đối chiếu logic mã nguồn với yêu cầu chức năng và quy tắc nghiệp vụ. Người thực hiện xác định yêu cầu tương ứng, vị trí code xử lý và sự phù hợp giữa hai nội dung. Nếu cần khẳng định hành vi khi chạy, kết quả rà soát phải được bổ trợ bằng kiểm thử phù hợp.

Độ tin cậy (Reliability) chỉ được xem xét khi liên quan trực tiếp tới phạm vi. Ví dụ, quy định Vira yêu cầu một số thao tác cập nhật trạng thái, di chuyển, xóa mềm hoặc khôi phục task gửi kèm version hiện tại để hỗ trợ optimistic locking. Nếu các thao tác này thuộc phạm vi, cần kiểm tra việc truyền và xử lý version; kết quả không được khái quát thành đánh giá độ tin cậy toàn hệ thống.

1.3.3. Chuyển mô hình thành tiêu chí có thể kiểm tra

ISO/IEC 25010 cung cấp nhóm đặc tính chất lượng ở mức mô hình. Để áp dụng vào nhiệm vụ cá nhân, mỗi đặc tính được chọn cần chuyển thành câu hỏi kiểm tra, phương pháp đánh giá và yêu cầu minh chứng. Ví dụ dưới đây định hướng việc lập checklist; trạng thái đánh giá chỉ được điền sau khi kiểm tra thực tế.

Bảng 1.2. Ánh xạ đặc tính chất lượng vào rà soát mã nguồn

Đặc tính	Câu hỏi rà soát mẫu	Minh chứng cần lưu
Khả năng bảo trì	Cấu trúc module và trách nhiệm lớp/hàm có rõ; cách đặt tên có nhất quán với chuẩn dự án không?	File, lớp/hàm, vị trí code và nhận xét.
Bảo mật	Backend có kiểm tra quyền trước thao tác nhạy cảm và giới hạn đúng phạm vi Workspace/Project không?	Endpoint/service, vị trí kiểm tra quyền và quy tắc đối chiếu.
Tính phù hợp chức năng	Logic xử lý có phù hợp yêu cầu hoặc quy tắc nghiệp vụ được viện dẫn không?	Mã yêu cầu/quy tắc và phần code tương ứng.
Độ tin cậy trong phạm vi liên quan	Thao tác task được kiểm tra có truyền/xử lý version theo quy định không?	Request, service hoặc đoạn cập nhật tương ứng.

1.4. Kết luận phần 1

Waterfall được chọn làm mô hình tham chiếu để xác định vị trí, đầu vào và đầu ra của hoạt động rà soát mã nguồn cá nhân. ISO/IEC 25010 được lựa chọn để hình thành tiêu chí chất lượng, tập trung vào khả năng bảo trì, bảo mật và tính phù hợp chức năng; độ tin cậy được xem xét giới hạn khi liên quan đến thao tác thuộc phạm vi. Đây là cơ sở cho tiêu chuẩn tài liệu và quy trình ở các phần tiếp theo.

2. THIẾT LẬP BỘ TIÊU CHUẨN TÀI LIỆU SQA CHO DỰ ÁN

2.1. Mục đích và phạm vi áp dụng

Bộ tiêu chuẩn tài liệu SQA quy định cách nhận diện, cấu trúc, đặt tên, quản lý phiên bản, rà soát, phê duyệt và lưu trữ tài liệu dùng trong nhiệm vụ

cá nhân. Mục tiêu là bảo đảm tài liệu nhất quán, truy vết được và phản ánh đúng phần mã nguồn đã kiểm tra.

Tiêu chuẩn áp dụng cho tài liệu cá nhân phục vụ rà soát mã nguồn Vira: kế hoạch/phạm vi rà soát, quy ước và tiêu chí áp dụng, quy trình rà soát, checklist, phiếu ghi nhận phát hiện và báo cáo kết quả. Nội dung tham khảo bài giảng về tiêu chuẩn tài liệu, quy trình review, checklist và thủ tục QA [4], [5].

2.2. Cấu trúc chung của tài liệu SQA

Mỗi tài liệu cần có khối thông tin kiểm soát gồm mã, tên, phiên bản, ngày ban hành/cập nhật, người soạn, người rà soát/phê duyệt và trạng thái. Phần nội dung cần nêu mục đích, phạm vi, thuật ngữ cần thiết, căn cứ tham chiếu, nội dung chính và lịch sử thay đổi. Checklist hoặc báo cáo phát hiện cần bổ sung mã lần rà soát, module, phiên bản code và minh chứng.

Bảng 2.1. Trường thông tin kiểm soát tài liệu

Trường	Quy định
Mã và tên	Mã duy nhất theo quy tắc tại Mục 2.3; tên thể hiện đúng nội dung.
Phiên bản và ngày	Ghi phiên bản hiện hành và ngày lập/cập nhật theo ngày/tháng/năm.
Người soạn	Cá nhân thực hiện nhiệm vụ chịu trách nhiệm về nội dung và tính đầy đủ.
Người rà soát/phê duyệt	Ghi người có thẩm quyền thực tế; có thể là giảng viên/người hướng dẫn nếu học phần yêu cầu. Trước khi duyệt ghi “Chờ rà soát”, không ghi đã phê duyệt.
Mục đích/phạm vi	Nêu mục tiêu tài liệu và phần dự án/lần rà soát áp dụng.
Tham chiếu	Nêu yêu cầu Vira, coding standards, tài liệu môn học hoặc tiêu chuẩn sử dụng.

Trường	Quy định
Lịch sử thay đổi	Ghi phiên bản, ngày, nội dung cập nhật và người cập nhật.

2.3. Quy tắc mã và tên tài liệu

Mã tài liệu sử dụng cấu trúc VIRA-SQA-[LOẠI]-[SỐ THỨ TỰ]. VIRA nhận diện dự án; SQA nhận diện nhóm tài liệu đảm bảo chất lượng; LOẠI mô tả loại tài liệu; SỐ THỨ TỰ là hai chữ số tăng dần. Tên file gồm mã tài liệu, tên rút gọn, phiên bản và ngày cập nhật; không sử dụng tên chung chung hoặc khó phân biệt.

Bảng 2.2. Danh mục tài liệu dùng cho nhiệm vụ cá nhân

Mã đề xuất	Tên tài liệu	Mục đích và người chịu trách nhiệm
VIRA-SQA-PLN-01	Kế hoạch SQA cá nhân	Nêu mục tiêu, phạm vi, tiêu chí, lịch và cách lưu hồ sơ. Soạn: cá nhân thực hiện.
VIRA-SQA-STD-01	Quy ước rà soát mã nguồn	Tập hợp quy ước dự án và tiêu chí chất lượng. Soạn: cá nhân, căn cứ tài liệu dự án.
VIRA-SQA-PROC-01	Quy trình rà soát mã nguồn	Mô tả trách nhiệm, đầu vào, các bước, đầu ra và điều kiện chấp nhận. Soạn: cá nhân.
VIRA-SQA-CHK-01	Checklist rà soát mã nguồn	Ghi tiêu chí, Đạt/Không đạt/Không áp dụng, minh chứng và hướng xử lý. Soạn: cá nhân.
VIRA-SQA-LOG-01	Phiếu phát hiện và theo dõi xử lý	Theo dõi mã phát hiện, mức độ, vị trí, người xử lý, trạng thái và rà soát lại. Cập nhật theo thực tế.

Mã đề xuất	Tên tài liệu	Mục đích và người chịu trách nhiệm
VIRA-SQA-RPT-01	Báo cáo kết quả rà soát	Tổng hợp phạm vi, phương pháp, kết quả, phát hiện, giới hạn và kết luận. Soạn: cá nhân.

Các mã trong bảng là quy ước đề xuất cho báo cáo này; cần dùng nhất quán giữa kế hoạch, quy trình, checklist, phiếu phát hiện và báo cáo. Nếu biểu mẫu giảng viên đã quy định mã khác thì thay thế đồng bộ.

2.4. Quy tắc đặt tên file và quản lý phiên bản

Tên file sử dụng mẫu VIRA-SQA-[LOẠI]-[SCOPE]_v[MAJOR.MINOR]_[YYYYMMDD].docx. SCOPE là module, chức năng hoặc phạm vi; phiên bản thể hiện lần ban hành/cập nhật; ngày dùng dạng năm-tháng-ngày. Ví dụ: VIRA-SQA-CHK-TASK_v1.0_20261028.docx. Nếu tài liệu lưu trong hệ thống quản lý phiên bản, tên file vẫn cần đủ rõ để nhận diện khi tải riêng.

Phiên bản 1.0 là bản đầu tiên được xác lập làm cơ sở sử dụng. Tăng số MINOR, ví dụ 1.1, khi sửa trình bày hoặc bổ sung giải thích mà không đổi phạm vi/tiêu chí cốt lõi. Tăng số MAJOR, ví dụ 2.0, khi thay đổi đáng kể phạm vi, trách nhiệm, quy trình hoặc tiêu chí. Mọi thay đổi phải cập nhật lịch sử phiên bản. Bản cũ được lưu riêng hoặc giữ lịch sử; không ghi đè làm mất khả năng truy vết.

Bảng 2.3. Mẫu lịch sử phiên bản

Phiên bản	Ngày	Mô tả thay đổi	Người cập nhật
1.0	28/10/2026	Ban hành lần đầu.	Cá nhân thực hiện
1.1	Khi cập nhật	Ghi rõ nội dung thay đổi.	Cá nhân thực hiện

2.5. Người soạn, người rà soát và người phê duyệt

Người soạn là cá nhân thực hiện báo cáo, chịu trách nhiệm xác định phạm vi, lập tài liệu, kiểm tra tính nhất quán và cập nhật phiên bản. Người rà soát/phê duyệt được xác định theo cơ chế học phần hoặc dự án; có thể là giảng viên, người hướng dẫn hoặc người được phân công. Việc quy định vai trò không đồng nghĩa tài liệu đã được duyệt; trạng thái phải phản ánh thực tế.

Trong rà soát code, tác giả mã nguồn và reviewer là hai vai trò nghiệp vụ khác nhau. Cá nhân thực hiện nhiệm vụ SQA rà soát theo checklist; người phụ trách code tiếp nhận và xử lý phát hiện. Nếu không có người độc lập kiểm tra lại, báo cáo phải nêu hạn chế và áp dụng bước tự rà soát lại.

2.6. Nội dung, trình bày và bảo mật

Tài liệu dùng tiếng Việt cho thuyết minh; thuật ngữ kỹ thuật và tên thành phần mã nguồn được giữ nguyên khi cần chính xác. Thuật ngữ cần được giải thích ở lần xuất hiện đầu tiên nếu có nguy cơ nhầm lẫn. Bảng, hình và checklist cần đánh số, có tên và ghi nguồn khi sử dụng nội dung ngoài dự án.

Nhận định phải phân biệt giữa quy định, đề xuất, quan sát và kết quả đã xác minh. Phát hiện cần mô tả vấn đề, vị trí, căn cứ, ảnh hưởng và hướng xử lý. Không đưa mật khẩu, token, khóa bí mật hoặc dữ liệu cá nhân vào tài liệu; minh chứng cần được che thông tin nhạy cảm.

2.7. Lưu trữ, truy vết và sử dụng tài liệu

Tài liệu được lưu trong thư mục riêng của báo cáo cá nhân hoặc vị trí học phần quy định. Kế hoạch SQA xác định phạm vi; quy ước/tiêu chuẩn cung cấp căn cứ; quy trình quy định cách làm; checklist ghi kết quả từng tiêu chí; phiếu phát hiện theo dõi xử lý; báo cáo tổng hợp kết quả. Mỗi phát hiện phải liên kết với mã tiêu chí, module/chức năng, đường dẫn file, phiên bản code nếu xác định được và trạng thái xử lý.

Trước khi nộp, người soạn kiểm tra mã tài liệu, phiên bản, ngày, tài liệu tham chiếu, tính đầy đủ bảng biểu và sự nhất quán giữa hồ sơ. Tài liệu chưa được giảng viên hoặc người hướng dẫn duyệt phải thể hiện đúng trạng thái.

2.8. Kết luận phần 2

Bộ tiêu chuẩn xác định cấu trúc, cách đặt mã và tên, quản lý phiên bản, vai trò soạn/rà soát/phê duyệt và danh mục tài liệu cần dùng cho nhiệm vụ cá nhân. Liên kết mã và phiên bản giữa các hồ sơ hỗ trợ truy vết từ yêu cầu chất lượng đến tiêu chí, phát hiện, xử lý và kết luận.

3. QUY TRÌNH SQA PHỤC VỤ RÀ SOÁT MÃ NGUỒN

3.1. Mục tiêu

Quy trình được thiết lập nhằm kiểm soát có hệ thống hoạt động rà soát mã nguồn cá nhân; phát hiện sai lệch so với yêu cầu và tiêu chuẩn; ghi nhận minh chứng; theo dõi xử lý; và kết luận trong phạm vi kiểm tra. Trọng tâm gồm coding standards, khả năng bảo trì và phân quyền; tính phù hợp chức năng hoặc quy tắc kỹ thuật được xem xét khi thuộc phạm vi.

Theo nội dung SQA trong tài liệu môn học, hoạt động chất lượng dựa trên quy trình, tiêu chuẩn, checklist và hồ sơ; rà soát mã nguồn là hoạt động kiểm soát sản phẩm, còn thiết lập và duy trì quy trình thuộc hoạt động đảm bảo chất lượng [2], [4], [5].

3.2. Phạm vi

Quy trình áp dụng cho file và chức năng thuộc nhiệm vụ cá nhân trong Vira. Trước mỗi lần rà soát cần ghi module, chức năng, danh sách file, nhánh/commit hoặc mốc phiên bản, yêu cầu liên quan và nội dung loại trừ. Với trọng tâm phân quyền, ưu tiên điểm kiểm tra quyền ở backend thuộc phạm vi được giao; với trọng tâm bảo trì, xem xét cấu trúc và quy ước mã nguồn của module được chọn.

Nếu người giao nhiệm vụ chỉ định module cụ thể thì phạm vi đó được ưu tiên. Nếu chưa chỉ định, người thực hiện thống nhất phạm vi có thể kiểm tra

và ghi vào phiếu rà soát trước khi bắt đầu. Quy trình không mặc định kết quả cho module nào và không đánh giá toàn bộ hệ thống nếu chưa rà soát toàn bộ.

3.3. Vai trò và trách nhiệm

Bảng 3.1. Vai trò trong quy trình rà soát cá nhân

Vai trò	Trách nhiệm
Người thực hiện SQA / reviewer	Lập phạm vi, chuẩn bị căn cứ, rà soát theo checklist, ghi phát hiện, bảo vệ minh chứng và lập kết luận.
Tác giả/người phụ trách mã nguồn	Giải thích ý định thiết kế khi cần; tiếp nhận phát hiện và sửa đổi theo phân công thực tế.
Người hướng dẫn/phê duyệt	Xem xét kết quả khi học phần hoặc dự án yêu cầu; xác nhận trạng thái theo thực tế.
Người rà soát lại	Kiểm tra phát hiện đã sửa; nếu reviewer tự kiểm tra, ghi rõ là tự rà soát và hạn chế về tính độc lập.

Do đây là tiểu luận cá nhân, người thực hiện chịu trách nhiệm chính về hoạt động SQA. Các vai trò tác giả code, reviewer và người hướng dẫn được nêu để phân định trách nhiệm; tên cá nhân và trạng thái phê duyệt chỉ ghi khi có dữ liệu thực tế.

3.4. Đầu vào

Trước khi rà soát, người thực hiện chuẩn bị các đầu vào sau:

- Phạm vi module/chức năng và danh sách file cần rà soát.
- Mã nguồn tại nhánh, commit hoặc phiên bản có thể nhận diện.
- Yêu cầu chức năng, quy tắc nghiệp vụ và tài liệu thiết kế liên quan nếu có.
- Coding standards, quy định bảo mật và quy tắc phân quyền của dự án.
- Tiêu chí ánh xạ từ ISO/IEC 25010 và checklist đúng phiên bản.
- Phiếu ghi kết quả, mẫu phát hiện và công cụ đọc/tìm kiếm code nếu có sử dụng.

Nếu tài liệu đầu vào không tồn tại hoặc không thể truy cập, người thực hiện ghi nhận thiếu hụt. Trạng thái có thể là “Chưa đủ thông tin”; không chuyển thành Đạt dựa trên suy đoán.

3.5. Trình tự thực hiện

3.5.1. Bước 1 - Khởi tạo và xác định phạm vi

Ghi mã lần rà soát, ngày, phạm vi chức năng/module, file, phiên bản code và nội dung loại trừ. Phạm vi cần đủ nhỏ để mỗi tiêu chí có thể được kiểm tra và minh chứng. Xác định rủi ro trọng tâm theo nhiệm vụ, ưu tiên quyền truy cập, tính toàn vẹn dữ liệu và khả năng bảo trì.

3.5.2. Bước 2 - Chuẩn bị tiêu chí và tài liệu

Thu thập yêu cầu, quy tắc dự án và quy ước mã nguồn; chọn checklist phù hợp. Mỗi tiêu chí thể hiện nội dung kiểm tra, căn cứ, phương pháp đánh giá và loại minh chứng cần lưu. Tiêu chí không áp dụng được đánh dấu và giải thích.

3.5.3. Bước 3 - Rà soát mã nguồn

Đối chiếu mã nguồn với từng tiêu chí: cách đặt tên và cấu trúc; trách nhiệm lớp/hàm; khả năng truy vết luồng xử lý; kiểm tra xác thực và phân quyền ở backend; sự phù hợp với quy tắc nghiệp vụ; và quy tắc kỹ thuật như optimistic locking khi thuộc phạm vi. Với quyền truy cập, lần theo luồng từ endpoint tới service hoặc nơi thực thi chính sách quyền, không chỉ quan sát trạng thái giao diện.

Rà soát tập trung vào phát hiện có thể mô tả và tái kiểm tra. Nếu việc sửa ngay có thể làm mất dấu trạng thái ban đầu, ghi nhận phát hiện trước; sau đó mới xử lý theo phân công và quy trình quản lý thay đổi của dự án.

3.5.4. Bước 4 - Ghi nhận và phân loại phát hiện

Mỗi phát hiện được cấp mã duy nhất, ghi tiêu chí liên quan, mô tả, file/vị trí, căn cứ đối chiếu, ảnh hưởng, mức độ, hướng xử lý và trạng thái. Minh

chứng có thể là đường dẫn file, tên lớp/hàm, số dòng, commit hoặc ảnh/log đã loại dữ liệu nhạy cảm.

Bảng 3.2. Thang phân loại phát hiện đề xuất

Mức độ	Nguyên tắc phân loại	Ví dụ trong phạm vi rà soát
Nghiêm trọng	Có thể dẫn đến truy cập trái phép, sai lệch dữ liệu lớn hoặc hỏng chức năng trọng yếu.	Thiếu kiểm tra quyền ở thao tác nhạy cảm làm lộ dữ liệu ngoài phạm vi.
Cao	Ảnh hưởng đáng kể tới chức năng, quy tắc nghiệp vụ hoặc tính toàn vẹn dữ liệu.	Luồng xử lý bỏ qua quy tắc quyền hoặc cập nhật dữ liệu quan trọng sai.
Trung bình	Làm giảm khả năng bảo trì, gây sai lệch một phần hoặc tăng rủi ro lỗi.	Logic khó truy vết hoặc xử lý version thiếu nhất quán trong luồng được kiểm tra.
Thấp	Vấn đề nhỏ về tính nhất quán hoặc khả năng đọc, chưa có ảnh hưởng trực tiếp đáng kể.	Tên gọi/cấu trúc chưa theo quy ước nhưng chưa làm sai hành vi.

Đây là thang phân loại đề xuất cho nhiệm vụ cá nhân, không phải mức phân loại được khẳng định là quy định chính thức của ISO/IEC 25010. Người rà soát cần nêu lý do khi phân loại.

3.5.5. Bước 5 - Trao đổi và xử lý phát hiện

Phát hiện được chuyển cho người phụ trách mã nguồn hoặc người giao nhiệm vụ theo cơ chế thực tế. Phản hồi được ghi nhận theo trạng thái: chấp nhận, cần làm rõ, không chấp nhận kèm lý do hoặc hoãn xử lý có nêu rủi ro. Nếu cá nhân trực tiếp sửa code, cần ghi nhận thay đổi và phân biệt trạng thái trước/sau sửa.

3.5.6. Bước 6 - Rà soát lại

Sau khi có thay đổi, kiểm tra lại đúng tiêu chí và phạm vi bị ảnh hưởng. Cập nhật trạng thái thành Đã khắc phục, Chưa khắc phục, Hoãn xử lý/Chấp nhận rủi ro hoặc Đóng không sửa theo quyết định thực tế. Không đóng phát hiện chỉ dựa trên thông báo đã sửa; cần có bằng chứng rà soát lại.

3.5.7. Bước 7 - Tổng hợp và kết thúc

Tổng hợp số tiêu chí Đạt, Không đạt, Không áp dụng/Chưa đủ thông tin; số phát hiện theo mức độ và trạng thái; phát hiện còn mở; giới hạn của lần rà soát. Báo cáo kết luận nêu phạm vi, phiên bản code, checklist và thời điểm sử dụng. Hồ sơ được lưu theo tiêu chuẩn tài liệu tại Mục 2.

3.6. Đầu ra

Bảng 3.3. Đầu ra và hồ sơ của quy trình

Đầu ra	Nội dung tối thiểu
Phiếu phạm vi rà soát	Mã lần rà soát, người thực hiện, module/file, phiên bản code, yêu cầu liên quan.
Checklist hoàn thành	Mã tiêu chí, cách kiểm tra, trạng thái, minh chứng, nhận xét và hướng xử lý.
Danh sách phát hiện	Mã, mức độ, mô tả, vị trí, căn cứ, người xử lý, trạng thái và kết quả rà soát lại.
Báo cáo kết quả	Phương pháp, phạm vi, thống kê, kết luận và giới hạn đánh giá.
Hồ sơ thay đổi/liên kết	Commit hoặc đường dẫn thay đổi nếu phát hiện đã sửa và thông tin truy vết.

3.7. Điều kiện chấp nhận và tiêu chí kết thúc

Một lần rà soát hoàn tất về mặt hồ sơ khi phạm vi và phiên bản code được xác định; mọi tiêu chí áp dụng có trạng thái; mỗi mục Không đạt có mô

tả và minh chứng; mỗi mục Không áp dụng hoặc Chưa đủ thông tin có lý do; phát hiện có trạng thái xử lý; và kết luận giới hạn trong bằng chứng đã thu thập.

Để đề xuất chuyển phần code đã rà soát sang kiểm thử, không còn phát hiện Nghiêm trọng chưa xử lý trong phạm vi; phát hiện Cao được xử lý hoặc có quyết định chấp nhận rủi ro được ghi nhận; phát hiện còn lại có kế hoạch xử lý. Đây là điều kiện đề xuất cho báo cáo cá nhân và cần điều chỉnh nếu dự án hoặc giảng viên quy định ngưỡng khác. Kết quả không đồng nghĩa với nghiệm thu toàn bộ sản phẩm.

3.8. Minh chứng và kiểm soát hồ sơ

Minh chứng phải đủ để người khác kiểm tra lại kết luận. Hồ sơ ghi ít nhất mã và ngày rà soát; người thực hiện; phạm vi; nhánh/commit hoặc phiên bản; mã và phiên bản checklist; tiêu chí; kết quả; vị trí file/code; phát hiện; hướng xử lý; trạng thái rà soát lại. Ảnh chỉ dùng bổ trợ, không thay thông tin đường dẫn và vị trí truy vết. Dữ liệu nhạy cảm phải được che hoặc loại bỏ.

3.9. Hạn chế của rà soát cá nhân và biện pháp kiểm soát

Rà soát do một cá nhân thực hiện có hạn chế về tính độc lập và nguy cơ bỏ sót do quen thuộc với mã nguồn hoặc diễn giải chủ quan. Để giảm rủi ro, người thực hiện dùng checklist đã xác định trước, đối chiếu từng tiêu chí với căn cứ, lưu vị trí minh chứng, đọc lại phát hiện trước khi kết luận và đề nghị người hướng dẫn xem xét phát hiện nghiêm trọng nếu điều kiện học phần cho phép. Báo cáo cần nêu giới hạn này, không trình bày kết quả như một cuộc kiểm toán độc lập.

3.10. Kết luận phần 3

Quy trình xác định mục tiêu, phạm vi, vai trò, đầu vào, trình tự thực hiện, đầu ra, điều kiện chấp nhận và cách lưu minh chứng cho hoạt động rà soát mã nguồn cá nhân. Quy trình là cơ sở để áp dụng checklist, theo dõi phát

hiện và lập báo cáo kết quả. Kết luận chỉ được đưa ra sau khi có minh chứng từ mã nguồn thực tế.

TÀI LIỆU THAM KHẢO

[1] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 01. Tổng quan về đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[2] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 03. Các hoạt động đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[3] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 05. Chuẩn và mô hình chất lượng”, tài liệu bài giảng do giảng viên cung cấp; mô hình ISO/IEC 25010 theo phiên bản trình bày trong tài liệu môn học.

[4] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 07. Hệ thống đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[5] Tài liệu học phần Đảm bảo chất lượng phần mềm, “Bài 08. Thiết lập và vận hành hệ thống đảm bảo chất lượng phần mềm”, tài liệu bài giảng do giảng viên cung cấp.

[6] Vira Project, “AGENTS.md - Project Guidelines” và “Đặc tả yêu cầu phần mềm - Vira”, tài liệu dự án.